
Bachelor's Thesis Proposal

Modeling the Information Accountability in Software Systems

Assessor: Dr. Hoang Nguyen
Co-assessor: To be decided

1 Motivation

(Personal) Data is now collected, shared, and combined at a scale that individuals can no longer follow. Privacy protection has traditionally focused on controlling access: keeping data secret and deciding in advance who may see it. This approach alone is no longer enough [2]. Once information has been disclosed, it can be copied, aggregated, and reused in ways that access control cannot prevent. As a complementary approach, Weitzner et al. [2] propose information accountability, i.e., the use of information should be transparent so that it is possible to determine afterwards whether a particular use was appropriate under the applicable rules and to hold those responsible for misuse accountable. Regulation such as the GDPR [1] points in the same direction. It requires data controllers to be able to demonstrate compliance (Art. 5(2)) and grants individuals a right of access to information about how their data is processed (Art. 15).

In practice, organizations already log access to personal data, but those logs are built for admins and auditors, not for the people to whom the data pertains. As far as end-users are concerned, they cannot easily see who accessed their data, why, under which legal basis, or what came of it.

2 Objective

In this thesis, we focus on personal data. We start from a design that can already identify personal data and its owners. The goal of this thesis is to extend this design so that it is able to specify accountability for personal data.

3 Tasks

1. Study the current design for storing and detecting personal data and ownership.
2. Design a conceptual extension that allows the system to store accountability for personal data.
3. Design an activity diagram describing how data subjects view the usage of their personal data.
4. Implement the design and (part of) the activity diagram in a typical relational database management system.
5. Validate the extended approach in a case-study application.
6. Document the design, implementation, and evaluation in the final report.

4 Deliverables

The following deliverables are due at the end of the project:

Final report Please have a look at the submission requirements in the following section. The final report should consist of an introduction, a (theoretical) background section, sections describing the work packages and their outcomes, and a conclusion. The report must be written in English.

Source code Complete, documented source code with a reproducible evaluation is required.

Presentation At the end of the thesis, a 20-minute presentation must be given in a thesis defense seminar. It should provide an overview and discuss the most important highlights of the work.

References

- [1] European Parliament and Council. Regulation (EU) 2016/679, 2016. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.
- [2] Daniel J. Weitzner, Harold Abelson, Tim Berners-Lee, Joan Feigenbaum, James Hendler, and Gerald Jay Sussman. Information accountability. *Commun. ACM*, 51(6):82–87, June 2008.